

Highlights

Certifying AI Agents Under the Common Criteria and Emerging Assurance Frameworks

Joo Yeon Cho

- Agent certificates record verdicts while evaluation pipelines measure rates.
- The language model belongs outside the TSF; only deterministic parts bear SFRs.
- Every path from model proposal to external effect must be enumerated.
- LLM judges are measurement instruments and need reported confusion matrices.
- An assurance ladder graded on agent autonomy and blast radius is proposed.

Certifying AI Agents Under the Common Criteria and Emerging Assurance Frameworks

Joo Yeon Cho^{a,*}

^aDepartment of Defense AI Convergence, Hongik University, Seoul, Republic of Korea

ARTICLE INFO

Keywords:

Common Criteria
ISO/IEC 15408
AI agents
security certification
assurance levels
measurement uncertainty

ABSTRACT

Enterprise deployment of autonomous AI agents has accelerated faster than formal standardization. While emerging industry-led standards (such as AIUC-1) bind controls to executable adversarial evidence rather than policy attestations, they suffer from critical structural limitations: non-monotone assurance reporting, absent compositional interfaces for foundation model vendors, loss of cross-evaluation comparability, and unquantified error in LLM-based measurement instruments. On the other hand, formal cybersecurity frameworks like the Common Criteria (ISO/IEC 15408:2022) offer established compositional methodology and graded assurance, but rely on assumptions that agentic systems fundamentally violate for determinism, decomposability of security functions, and stable target configurations.

This paper analyzes the emerging landscape of AI agent security certification. We systematize five core mismatches between formal security standards and agentic systems, and identify four gaps in current empirical evaluation pipelines. Then, we synthesize a unified adaptation framework designated AICC. AICC establishes: (1) the *Boundary Isolation*, placing stochastic models outside the Target of Evaluation (TOE) boundary with complete egress-path mediation; (2) a *Three-Role Composition Model* adapting smartcard composite methodology; (3) *Statistical Conformance and Metrological Qualification* for LLM judges with propagated confusion matrices; and (4) an *Agent Evaluation Assurance Level (AEAL)* tied to autonomy and blast radius. Finally, we provide a unified taxonomy mapping OWASP Agentic Top 10 threats to Security Functional Requirements (SFRs) and crosswalk AICC against the EU AI Act, EUCC, and AIUC-1.

1. Introduction

An autonomous AI agent equipped with credentials to API endpoints, database execution environments, or payment channels converts model inference directly into external physical or digital effects at machine speed. The security failure modes of such systems are fundamentally novel. Rather than conventional memory corruption, crashed processes, or unauthorized database leaks, an agent failure typically manifests as an action that was fully authorized, executed correctly by the underlying protocol, yet fundamentally incorrect or malicious.

Enterprise adoption is currently bottlenecked by risk that cannot be reliably assessed or priced. Buyers cannot distinguish between vendors who invest heavily in defensive engineering and those who rely on baseline models, so they pay only for the average and the careful vendor's investment is not rewarded. Certification is the standard remedy for this class of market failure, and it is being sought urgently by insurers, enterprise buyers, and regulatory bodies [9]. This paper addresses not whether AI agents will be certified, but whether the resulting certificates will carry enough information to be worth anything.

1.1. Motivations

Industry bodies (e.g., the Artificial Intelligence Underwriting Company (AIUC) consortium [1]), international standards bodies (ISO/IEC JTC 1/SC 27), OWASP [3],

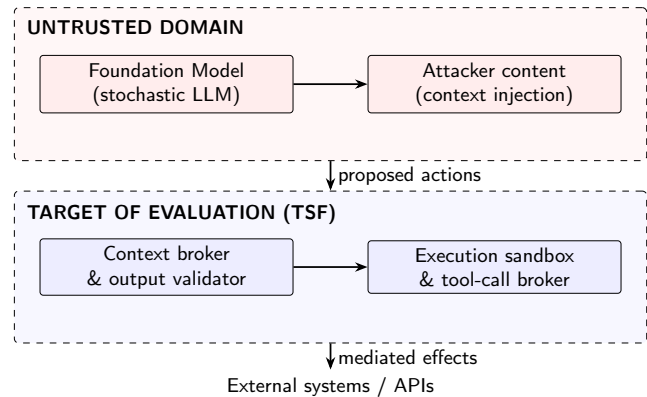


Figure 1: The Target of Evaluation boundary under the AICC Boundary Isolation. The model proposes; only deterministic components enforce. Every path from proposal to external effect must be enumerated and mediated (ADV_FSP-A).

and European cyber agencies (ENISA, CEN-CENELEC) are publishing non-overlapping, incompatible control taxonomies. Current agent security standards grade breadth (how many controls apply) rather than depth (how rigorously controls were evaluated). Modern agent evaluation relies heavily on “LLM-as-a-Judge” automated scoring. However, the metrological uncertainty and confusion matrices of these judges are rarely reported, leading to evaluation regimes dominated by instrument measurement error.

*Corresponding author.

✉ jooyeon.cho@hongik.ac.kr (J.Y. Cho)
ORCID(S): 0000-0003-0351-0885 (J.Y. Cho)

1.2. Contributions

We analyze five foundational assumptions of ISO/IEC 15408 [7] (Determinism, TSF Decomposability, JIL Attack Potential, Configuration Stability, and Economics) and detail why they fail for agentic AI. We evaluate empirical agent standards (focusing on AIUC-1 [1]) and identify four structural gaps preventing monotone risk pricing. We synthesize a comprehensive adaptation strategy introducing the *Boundary Isolation*, *Egress-Path Completeness*, *Base-Component Guidance*, and *Statistical Conformance*. Finally, we map OWASP Agentic Top 10 threats [3], security objectives, and extended functional and assurance components into a standardized Protection Profile (PP) schema.

1.3. Sources and Their Standing

Claims about AIUC-1's published structure derive from the standard itself [1] and from the joint OWASP-AIUC crosswalk [4]. Claims about its internal evaluation pipeline, such as test volumes, judge tuning procedure, and specific remediation figures, derive from a technical talk by AIUC staff. Such claims are not citable as published material and are reported here only where they illustrate a structural point that does not depend on the specific numbers.

2. Systematization of the Certification Landscape

Efforts to govern AI systems fall into three traditions. **Empirical Control Standards** originate from SOC 2 / ISO 27001 lineages; **Formal Evaluation Frameworks** derive from ISO/IEC 15408 (Common Criteria) [7]; and a third, **Institutional Deployment Governance**, has emerged from large organizations that must admit agents into production before any certificate exists. Stanford University's AI Security Framework (AISF) [5] is the clearest published instance: it explicitly integrates AIUC-1, ISO 42001, the NIST AI RMF, the EU AI Act and OWASP AIVSS into a single risk-tiered deployment pathway. The distinction matters for this paper because the third tradition does not certify a product at all; it gates a deployment, and its unit of decision is an institutional admission rather than an assurance claim. Table 1 summarizes the three.

2.1. Empirical Industry Standards: The AIUC-1 Baseline

AIUC-1 represents the state of the art in industry-led agentic AI certification [1]. It defines 50 control requirements across six domain pillars: Data & Privacy, Security, Safety, Reliability, Accountability, and Society, coded by pillar (A–F) and tailored per engagement into an auditor-signed Statement of Applicability.

- **Evaluation Pipeline:** Evaluation relies on high-volume automated adversarial testing, reportedly executing up to 50,000 multi-turn test conversations per evaluation run.
- **Scoring Mechanics:** Attacking agents execute generated prompts against the target, and outputs are

classified using LLM-as-a-Judge models paired with human sampling.

- **Re-testing Frequency:** Re-testing occurs quarterly to maintain a 12-month certificate validity window [1].

2.2. Formal Standards: Common Criteria (ISO/IEC 15408:2022)

The Common Criteria framework separates Security Functional Requirements (SFRs), which state *what* a product does, from Security Assurance Requirements (SARs), which state *how thoroughly* that functionality has been verified [7]. This separation is the single feature that current agent security standards most need and most lack. Evaluation methodology is defined in the companion CEM [8].

- **Target of Evaluation (TOE):** The specific software/hardware configuration undergoing evaluation.
- **TOE Security Functionality (TSF):** The set of hardware and software functions that enforce security policies.
- **Protection Profiles (PP) & Security Targets (ST):** PPs define implementation-independent requirement templates for standard product types; STs state the specific security claims of a vendor product.

3. Prior and Concurrent Work on Certifying AI Under CC

Applying CC to AI systems is an active programme rather than an open question. A BSI, BAUTA and TÜVIT collaboration has assessed the suitability of the CC scheme for AI-based video analysis systems at EAL2 [2]. It developed evaluation methodology covering threat analysis, security objectives and SFR testing with attention to ML characteristics. That work, like most of the small existing literature, treats the AI system as the TOE, placing the model inside the evaluated boundary. This is defensible for a perception component whose inputs are sensor data rather than attacker-authored instructions, and Section 5.1 argues it cannot be sustained for tool-using agents.

Two concurrent efforts bear directly on this paper. Nielson et al. [10] argue that CC is philosophically rooted in determinism and that the stochastic nature of LLMs challenges the core tenets of the ADV and ATE classes. Then, they propose an EAL2 strategy treating the LLM as a Non-TSF component isolated within a trusted boundary, satisfying ADV_ARC and AVA_VAN through deterministic *mediator* components. This is the same architecture as our Boundary Isolation, reached independently and in the same vocabulary; we make no priority claim over it, and Section 5.1 states what changes when the target is a tool-using agent rather than a system containing a model. Azouani et al. [6] develop a modular, model-agnostic Protection Profile for machine-learning systems anchored to the harmonized cybersecurity standard prEN 18282; our threat taxonomy (Table 3) is complementary, supplying agent-specific content that would fit such a profile as a PP-Module.

Table 1

Three traditions in AI system governance and evaluation.

Dimension	Empirical Standards (AIUC-1)	Institutional (Stanford AISF)	Governance	Formal Frameworks (ISO/IEC 15408)
Primary Goal	Market deployment & insurance underwriting	Admitting agents to production without a bottleneck		Independent third-party security assurance
Unit of decision	Certificate over a product	Deployment pathway for one institutional use case		Certificate over a defined TOE
Evaluation Metric	Pass/fail over empirical attack suites	Risk tier $\times$ agent category $\rightarrow$ self-service or review		Grades of assurance depth (EAL 1–7)
TOE Boundary	Entire agent system (including weights)	The deployed system in its institutional context		Strict TSF boundary (deterministic software)
Composition Model	Supply-chain due diligence	Highest category governs in a call chain		Formal composite evaluation (ETR reuse)
Measurement	High-volume automated LLM-as-a-judge scoring	Deployer self-certification; review only at high risk		Evaluator manual/scripted testing
Change Management	Periodic re-testing (quarterly / annual)	Enumerated re-classification triggers		Configuration baseline binding & delta evaluation
Regulatory Standing	Private consortium / insurer acceptance	Internal to the institution		Mutual recognition across 30+ CCRA states

4. Structural Gaps and Mismatches

4.1. Gap 1: Rates are Measured; Binary Verdicts are Recorded

Empirical evaluation pipelines generate quantitative failure rates. One reported engagement measured an 11% hallucination rate on material information, remediated to under 2% by the addition of a groundedness filter [11]. The issued certificate collapses both the pre- and post-remediation systems into the same binary “requirement met” verdict. It cannot distinguish the remediated system from one that entered at 2%, from one at 0.3%, or from one whose 2% was measured over a narrower input distribution.

This is not solely our observation. The OWASP–AIUC crosswalk states that it identifies relevance rather than sufficiency: a requirement mapped as *Primary* against a threat addresses that threat’s core risk. However, this does not mean the requirement as defined provides complete mitigation, and organizations are directed to evaluate implementation depth, testing coverage and operational maturity for themselves [4]. That instruction is an admission that the artifact does not carry the information its reader needs.

The consequence is economic: premium differentiation requires a monotone assurance scalar, and breadth is not one [9].

4.2. Gap 2: Roles Without a Composition Argument

Empirical frameworks distinguish between *Developers* (who build platforms) and *Deployers* (who configure context). However, they lack a formal evidence interface to carry assurance across this boundary:

- A deployer overrides a default setting without knowing which certified security claims depended on that setting.

- Updating an underlying base LLM model from version V_1 to V_2 invalidates safety assumptions without triggering an explicit evaluation invalidation.
- Foundation model labs are third parties to both developer and deployer, yet safety claims rely directly on model properties.

The crosswalk reaches the same conclusion from the threat side: AIUC-1 covers vendor due diligence and change approvals but requires no attestation artifacts specific to agentic components, that is, no tool manifests, no prompt version control, no agent dependency bills of materials, no content-hash pinning [4]. These are instances of one missing artifact: a statement of what a component guarantees and under what conditions.

4.3. Gap 3: Tailoring Costs Comparability

Empirical standards permit per-audit requirement exclusion with auditor-approved justification [4]. This mirrors Common Criteria’s “demonstrable conformance” mode, which historically led to pairwise incomparable certificates and forced CC:2022 to introduce *exact conformance* [7].

4.4. Gap 4: The Unqualified Measurement Chain

Empirical testing relies on a stochastic chain: Attack Generator $\rightarrow$ Agent Executor $\rightarrow$ LLM Judge $\rightarrow$ Human Sample. Each stage is stochastic, and at the reported test volumes the human stage is necessarily a sample rather than a census. When LLM judges possess uncalibrated false-positive (α) and false-negative (β) error rates, measurement uncertainty dominates the reported pass/fail statistics at low failure prevalences, as quantified in Section 5.4. A further hazard is correlation: where the attack generator is tuned against feedback from judges of the same model family that later score the results, blind spots are shared and invisible by construction.

Table 2

Five mismatches between ISO/IEC 15408 and agentic AI systems.

CC Assumption	Violation by Agentic AI Systems	AICC Adaptation Fix
1. Determinism	LLMs are inherently stochastic; output reproducibility is distribution-level.	Model placed outside TSF; deterministic brokers/validators enforce SFRs (§5.1).
2. TSF Decomposability	System prompts cannot self-protect; instruction and data streams share tokens.	Boundary Isolation: language model acts as an untrusted subject outside TSF (§5.1).
3. JIL Attack Potential	JIL scales attack potential by physical access/equipment, assuming high cost.	AVA_VAN-A: scales by query budget, transferability, and automation level (§5.5).
4. Configuration Stability	Agents evolve rapidly; models and tools change on multi-week release cycles.	Certified Configuration Envelope binds boundary rules and regression gates (§5.5).
5. Evaluation Economics	Traditional CC takes 12–24 months and six-figure budgets per evaluation.	Automated testing interface (AGD_EVI) and continuous evaluation pipeline (§5.5).

4.5. Five Mismatches in Common Criteria

Table 2 systematizes the primary structural mismatches between traditional Common Criteria assumptions and agentic AI systems.

5. The AICC Synthesis: Architectural and Assurance Adaptations

To bridge the gap between empirical testing and formal assurance, we propose AICC (Artificial Intelligence Certification under Common Criteria). See Figure 1 for the concept.

5.1. The Boundary Isolation and Egress-Path Completeness

Attempts to place the foundation model inside the Target of Evaluation (TOE) fail because stochastic neural weights cannot satisfy non-bypass, domain separation, or self-protection (ADV_ARC).

The Boundary Isolation: *In an AICC, the language model is defined as an untrusted subject operating outside the TSF boundary. Only deterministic orchestration components bear Security Functional Requirements (SFRs).*

5.1.1. Independent Convergence

This architecture is not ours alone, and that is the strongest available reason for believing it. Nielson et al. [10] reach it in CC’s own vocabulary (Section 3); the OWASP–AIUC crosswalk reaches it three times over from threat modeling, recommending guardrails enforced within agent code so that enforcement survives model substitution; structured schemas at the agent–model boundary under a “principle of most determinism”; and policy enforcement separating planning from execution [4]. Threat modeling, ADV_ARC tractability, and the observation that a TSF containing a stochastic component cannot be argued non-bypassable all terminate in the same place.

What AICC contributes is not the architecture but two consequences that follow once the target is an agent rather than a system containing a model. The first is *evaluability of the boundary*: guardrails placed in agent code can be satisfied by a filter no evaluator examines, on a path nobody

enumerated, with no argument that it cannot be circumvented. Modeling the same architecture as a TSF boundary converts it into obligations an evaluator can discharge. The second is that mediating an agent is harder than mediating a chatbot: when a model’s output is the product, a mediator on the conversational path suffices; when the output is a proposed action, the mediator must sit on every path by which a proposal becomes an effect, and the number of such paths is a property of the deployment rather than of the model.

5.1.2. Egress-Path Completeness (ADV_FSP-A)

If guardrails exist only on conversational text outputs, an agent can bypass safety checks by placing side-channel requests through secondary rendering or execution pipelines. In one reported case an agent with access to public and private repositories verbally refused an injected request for private code, while a separate image-rendering pipeline fetched and rendered it [12]. The guardrail was not defeated; it was simply not on the data path. In CC terms this is not a vulnerability in a security function but a *missing TSFI*.

ADV_FSP-A Requirement: The functional specification shall enumerate every path by which agent activity produces an effect outside the TOE. It includes tool invocation, network egress, file write, rendering pipelines, memory writes, sub-agent instantiation, and telemetry channels. It shall demonstrate that every path is mediated by a TSF enforcement point.

5.2. Three-Role Model and Base-Component Guidance

We extend CC’s composite-evaluation methodology (originally designed for smartcards, where an integrated circuit, a platform and an application are separately evaluated and composed) to support three distinct operational roles:

1. **Foundation Model Vendor:** Supplies the raw inference model alongside a standardized *Base-Component Guidance Document*.
2. **Agent Platform Developer:** Builds deterministic scaffolds, brokers, and execution sandboxes.

3. **Enterprise Deployer:** Configures tools, context sources, domain boundaries, and deployment parameters.

5.2.1. The Base-Component Guidance

The foundation model vendor supplies a specification stating:

- Context composition limits (prohibited mixing of context security tiers).
- Approved decoding parameters (temperature ranges, top- p bounds).
- Structural system-prompt assumptions and privilege boundaries.
- Modality pipeline constraints (ASR/TTS guardrail bounds).
- Known behavioral regressions with version-pinned hashes.

Downstream evaluations instantiate composite work units (ADV_COMP, ATE_COMP, AVA_COMP) against it. No such artifact exists: model cards and system cards address the public, not a downstream evaluator with defined obligations. Vendors have weak commercial incentive and real liability exposure in publishing one, so the forcing functions are large-buyer procurement terms, insurer coverage conditions, or EUCC and EU AI Act recognition.

A sharper objection comes from the deployer side. AISF makes *information disclosure discipline* a governing principle: vendors, datasets, model versions and system prompts are disclosed only on a need-to-know basis, since publication enlarges the attack surface, and high-risk systems withhold architecture and configuration entirely [5]. That appears incompatible with publishing version-pinned regressions and context composition limits.

CC resolved this long ago, which is itself an argument for reusing its machinery rather than inventing a disclosure regime. Evidence is split: the ETR is confidential to the evaluator, scheme and sponsor, while the ST and certification report are public but sanitized, stating claims and assurance level without the detail needed to attack the product. Base-component guidance belongs on the ETR side, addressed to a party under confidentiality rather than to the open web. The two requirements are therefore compatible. That AISF and this paper reach opposite conclusions from the same facts suggests the public-claim / confidential-evidence distinction is doing work neither empirical standards nor institutional governance makes explicit.

5.3. Statistical Conformance (ATE_STAT)

While CC verdicts are binary: a vulnerability exists or it does not, Agent security properties are probabilistic. CC has no vocabulary for a claim holding at a stated rate under a stated attacker budget. ATE_STAT supplies one. A conformance claim takes the form: property P holds with rate $\geq r$ at confidence c over input distribution D , measured with n trials against attacker budget B , using instrument J

with class-conditional error rates (α, β) . See Section 4.4 for definitions.

The distribution D must be declared and justified as representative of deployment; n is derived from r and c rather than chosen for convenience (for $r = 0.999$ at $c = 0.95$, one-sided binomial bounds require $n \approx 3000$ clean trials [16]); held-out sets are evaluator-designed rather than developer-supplied; and the evaluation environment must be realistic enough that evaluation-aware models exhibit deployment behavior. Levels .1 through .3 grade these from developer-run and evaluator-reviewed, through evaluator-supervised, to evaluator-designed and undisclosed with sandbagging checks.

5.4. Evaluative Metrology and Judge Qualification (ATE_JQL)

When an automated LLM judge is used to assess agent security properties, judge errors must be characterized using standard measurement uncertainty principles [18]. The unreliability itself is well documented: LLM judges exhibit position, verbosity and self-preference bias, and agreement with human labellers is far from unity [19]. CC contains no such requirement because it assumes evaluator tools are correct; that assumption is not valid here.

5.4.1. Mathematical Model of Judge Error

Let p be the true failure prevalence in the evaluation sample, α the false-positive rate on true negatives, and β the false-negative rate on true positives. This is the classical screening-test model, in which $1 - \beta$ is the sensitivity of the instrument and $1 - \alpha$ its specificity [13]. The observed positive rate $\hat{p}$ is expressed as:

$$\hat{p} = p(1 - \beta) + (1 - p)\alpha \quad (1)$$

The proportion of flagged failures that represent genuine system failures (Positive Predictive Value, PPV) is given by [17]:

$$\text{Pr}[\text{true failure} \mid \text{flagged}] = \frac{p(1 - \beta)}{p(1 - \beta) + (1 - p)\alpha} \quad (2)$$

The magnitude of the effect is easily underestimated. Consider a symmetric judge with $\alpha = \beta = 0.01$, informally described as “99% accurate,” applied at a true failure prevalence of $p = 0.01$. Of 10,000 samples, 100 are true failures of which 99 are detected; of the 9,900 passes, 99 are misflagged. The reported failure count is 198, of which *half are instrument artifacts*. At $\alpha = \beta = 0.10$ and the same prevalence, 90 true positives are accompanied by 990 false positives, and the measurement is over 90% noise. By (2) the tolerable α is a function of the prevalence being measured, and prevalence falls as systems improve: a judge good enough to certify an 11% hallucination rate is not good enough to distinguish 2% from 0.5%.

Instrument error must therefore be declared as a class-conditional pair and propagated rather than summarized as

a single accuracy figure. Inverting (1) yields the Rogan–Gladden estimator [13]:

$$\tilde{p} = \frac{\hat{p} - \alpha}{1 - \alpha - \beta} \quad (3)$$

whose confidence interval must incorporate uncertainty in α and β themselves, since both are estimated from finite validation samples [14, 15]. This is where small validation sets bite. Judge tuning is reported to proceed under data scarcity with as few as twenty human-labeled samples; a perfect 20-of-20 validation result supports a one-sided 95% lower confidence bound of $0.05^{1/20} \approx 0.86$ on judge accuracy by the exact binomial method [16], which is nowhere near sufficient at the prevalences above. Under AICC the required validation set size is derived from the prevalence of the property being judged, and is often uncomfortably large.

5.4.2. Requirements of ATE_JQL

- **ATE_JQL.1:** Developers must supply judge configurations, scoring rubrics, and human-labeled validation sets with reported class-conditional error rates (α, β) and confidence intervals.
- **ATE_JQL.2:** Evaluators must independently confirm judge error rates using evaluator-supplied datasets sized to the prevalence of the judged property.
- **ATE_JQL.3:** Evaluators must demonstrate structural independence between the attack generator and the scoring judge (distinct model families, distinct prompt lineages), and report residual correlation where independence cannot be achieved.

We expect ATE_JQL to generalize beyond AICC. Every AI evaluation regime now in circulation reports numbers produced by unqualified model-based judges, and to our knowledge no framework requires the confusion matrix. It is also the part of this work with no counterpart in the concurrent efforts of Section 3: the architectural question of where enforcement sits is being answered convergently by several groups, while the metrological question of how much to believe the resulting measurements is not being asked.

5.5. Attack Potential and Configuration Binding

5.5.1. AVA_VAN-A

JIL attack-potential scoring assumes cost dominated by expertise, equipment and physical access. For prompt injection, equipment is a text field and knowledge of the TOE is often obtainable by asking the TOE. AVA_VAN-A retains JIL’s scored-sum structure with replaced factors: *query budget* ($1/10^2/10^4/10^6+$, the natural cost unit for black-box attack); *expertise* and *knowledge of the TOE*, retained from JIL; *access* (single-turn, multi-turn, persistent memory, supply chain); *transferability* (target-specific, model-family, cross-model), which governs attack amortization; and *automation* (manual, scripted, optimizer-driven, adaptive-adversarial), which governs scaling. Levels .1–.5 follow by summed score, with .4 and .5 requiring an adaptive evaluator campaign rather than a fixed suite. A verdict is

a residual success rate at a stated budget rather than a binary “resistant,” which is the quantity an underwriter can price.

5.5.2. AGD_EVI and the Certified Configuration Envelope

Agents reachable by external API can be tested at volume; UI-only agents require costlier manual evaluation. AGD_EVI makes evaluability an assurance requirement rather than a scoping preference: the developer shall provide an interface exercising the TOE at stated throughput, with control over context composition, tool availability, principal identity and raw modality input, demonstrably equivalent to the production path.

Periodic re-testing proxies for what actually matters, which is change. The *Certified Configuration Envelope* binds the certificate instead to (i) the enforcement boundary — brokers, sandbox, validator and isolator by version and hash; (ii) the parameter envelope of permitted base models, decoding parameters, tool inventory and context composition rules; and (iii) a regression gate, itself evaluated under ATE_STAT and ATE_JQL, that must pass before any in-envelope change reaches production. In-envelope change requires a passing gate and a logged record; change outside it triggers re-evaluation. A schedule becomes a trigger condition: a silent model rebase currently waits up to a quarter for detection and under an envelope fails a gate immediately.

AISF enumerates re-classification triggers that read as envelope-exit conditions: expansion of accessible data, new tool calls, APIs or write permissions, change of audience, and material change in the underlying model including a system-prompt rewrite affecting capability or autonomy [5]. That an institution drew nearly the same boundary is evidence it is the natural one. The difference is who detects the crossing: AISF triggers are self-declared, so an unnoticed change produces no re-classification, where a regression gate fails mechanically. Enumerating the triggers is the harder step and AISF has taken it; instrumenting them is what makes the list an assurance argument.

6. Systematized Taxonomy of Agent Security Requirements

We systematize extended Security Functional Requirements (SFRs) and map them to the OWASP Top 10 for Agentic Applications [3] in Table 3. Four threats have no counterpart in the Top 10, and two of the mapped threats correspond to gaps the OWASP–AIUC crosswalk reports as uncovered by any AIUC-1 requirement [4].

6.1. Class FAG: Agent Autonomy Control

- **FAG_TCA** (Tool-Call Authorisation): Mandatory TSF verification of tool invocation context, authorization policy, and parameter constraints.
- **FAG_AUT** (Autonomy Level Enforcement): Restricts agent operational states and enforces formal transition rules between advisory, supervised, and autonomous execution.

- **FAG_ESC** (Escalation to Human Authority): Forces high-risk action classes to block until explicit human-in-the-loop approval is logged.
- **FAG_SCP** (Scope Confinement): Validates that proposed actions remain strictly within assigned operational task boundaries.
- **FAG_RVK** (Bounded-Latency Revocation): Terminates in-flight multi-turn executions within defined maximum time bounds upon revocation signals.

The bound is the part that is usually missing. AISF requires that an agent identity be “revocable in a single action” by the operational owner or the security office, and names this the technical foundation of its kill-switch requirement [5]. Single-action revocation is an interface property; it says nothing about how long an in-flight tool chain continues to execute after the action is taken. FAG_RVK states the missing half, and at AEAL 4 the bound must be evidenced rather than asserted.

The decomposition is not arbitrary. The OWASP-AIUC crosswalk observes that AIUC-1’s B006 (“prevent unauthorized AI agent actions”) is its most broadly mapped requirement, Primary against six of the ten agentic threats, and warns that it aggregates five distinct control functions: scope enforcement, tool-use restriction, privilege control, inter-agent constraints and runtime containment. Implementations should therefore address each independently rather than treating B006 as a single checkbox, since coverage of one does not imply coverage of the others [4]. A standard that must warn readers not to treat a requirement as a checkbox has a requirement doing too much work. Class FAG is that decomposition, each function separately stated, assigned and evaluated.

6.2. Class FGD: Output Grounding

- **FGD_ATT** (Attribution): Requires generated claims to carry verifiable, resolvable citations to retrieved source contexts.
- **FGD_ABS** (Abstention): Forces the system to yield structured abstention responses when grounding thresholds are unmet.
- **FGD_UNC** (Uncertainty Communication): Requires outputs to include calibrated confidence metrics across defined response classes.

FGD constrains the *validator*, not the model: FGD_ATT is satisfiable by a deterministic check that emitted claims carry citations resolving into the retrieved set. Claims not reducible to such a check do not belong in FGD and are handled as measured properties under ATE_STAT.

6.3. Modality Boundary Integrity (FDP_IFF-A)

Voice agents run automatic speech recognition, then a language model, then text-to-speech, with the ASR and TTS layers carrying their own guardrails distinct from the language layer. The TSF is therefore distributed across modality

transforms, each a place where integrity metadata is created, destroyed, or silently altered. FDP_IFF-A requires that the TSF preserve integrity and provenance labels across every modality transformation, or conservatively degrade the label to the lowest integrity level of any contributing input where preservation is not possible. Conservative degradation is the important half: an ASR layer that cannot determine whether a segment came from the enrolled speaker must label it untrusted rather than default to the session’s prevailing label.

7. The Agent Evaluation Assurance Level (AEAL) Ladder

AICC grades evaluation rigor on a five-tier Agent Evaluation Assurance Level scale indexed by agent autonomy (A_0 – A_4) and operational blast radius (B_0 – B_4). Table 4 gives the required components and defines both scales.

The two axes are not idiosyncratic. Stanford’s AISF classifies every in-scope agent by an Agent Deployment Category whose summary table carries a row named, in those words, *blast radius* — “bounded to the individual” through “bounded within Stanford” to “extends beyond Stanford” — and defines autonomy separately as the degree to which a system acts without human intervention [5]. An institution operating agents in production arrived independently at the same pair of dimensions. What differs is the output: AISF derives a *pathway*, self-service or review, where AEAL derives a *depth of evidence*. This is the breadth-versus-depth distinction of Section 4 once more.

Read generously, current industry certification reaches AEAL 2 for deterministically enforced requirements and AEAL 1 where measurement is developer-scoped; because instrument error is unreported it does not yet clear AEAL 1 on the ATE_JQL axis. Nothing in the field currently does, so this is not a mark against any particular standard.

8. Crosswalk and Regulatory Alignment

A central objective of AICC is providing a unified technical pathway that satisfies emerging global regulations without forcing vendors to undertake redundant evaluation regimes.

- **EU AI Act:** Article 43 permits conformity assessment for high-risk systems via internal control (Annex VI) or notified body (Annex VII). AICC Protection Profiles are a candidate basis for the harmonized-standard route under CEN-CENELEC JTC21, where prEN 18282 defines the AI-specific assets an evaluation would target [6].
- **EUCC Scheme:** Direct procedural reuse under the EU Cybersecurity Act via CC:2022 exact conformance, supplying accredited laboratories and national certification authorities without standing up a new scheme.
- **NIST AI RMF:** ATE_STAT statistical bounds and ATE_JQL judge error propagation supply evidence for the Measure and Manage functions.

Table 3

Systematized mapping of threats, objectives, and mapped AICC SFRs/SARs. Dashes indicate threats with no direct counterpart in the OWASP Agentic Top 10.

Threat	OWASP Mapping	Objective	Mapped SFRs / SARs
T.INJECT	ASI01 Agent Goal Hijack	O.PROVENANCE, O.MEDIATE	FDP_IFC.1, FDP_IFF.1, FAG_TCA.1, FAG_SCP.1
T.TOOL_ABUSE	ASI02 Tool Misuse & Exploitation	O.MEDIATE	FAG_TCA.1–.2, FTP_ITC.1
T.EGRESS_BYPASS	–	O.ENUMERATE, O.MEDIATE	ADV_FSP-A, FAG_TCA.1, FDP_ETC.2
T.EXCESS_AGENCY	ASI10 Rogue Agents	O.SCOPE, O.ESCALATE	FAG_SCP.1, FAG_AUT.1, FAG_ESC.1
T.CONTEXT_LEAK	ASI06 Memory & Context Poisoning	O.ISOLATE	FDP_IFC.1, FDP_ACC.1, FPR_UNL.1
T.SECRET_LEAK	ASI03 Identity & Privilege Abuse	O.SECRET	FDP_ACC.1, FDP_ETC.2, FCS_CKM.4
T.MODAL_BYPASS	–	O.LABEL_PRESERVE	FDP_IFF-A, ADV_FSP-A, ADV_ARC.1
T.SPEAKER_SPOOF	–	O.PRINCIPAL	FIA_UAU.5, FIA_UAU.7 (ISO/IEC 30107 PAD)
T.MEM_POISON	ASI06 Memory & Context Poisoning	O.PROVENANCE	FDP_IFF.1, FDP_SDI.2, FMT_MSA.3
T.SUPPLY	ASI04 Agentic Supply Chain	O.MEDIATE, O.DELEGATION	FIA_USB.1, FTP_ITC.1, FAG_TCA.1
T.UNGROUNDED_ACT	ASI08 Cascading Failures; ASI09 Trust Exploitation	O.GROUND, O.ESCALATE	FGD_ATT.1, FGD_ABS.1, FAG_ESC.1
T.AUDIT_EVADE	–	O.AUDIT	FAU_GEN.1–.2, FAU_STG.4
T.DELEGATE	ASI07 Inter-Agent Comms; ASI10 Rogue Agents	O.DELEGATION, O.REVOKE	FIA_USB.1, FMT_SMR.2, FAG_RVK.1

Table 4

The AEAL ladder. Levels are cumulative. Autonomy: A_0 advisory, A_1 supervised, A_2 bounded to an enumerated action set, A_3 open composition of novel action sequences, A_4 delegating. Blast radius: B_0 read-only single-principal, B_1 reversible single-principal write, B_2 multi-principal or irreversible write, B_3 production infrastructure or financial transfer, B_4 safety-of-life or critical infrastructure.

Level	Applicability	Required Assurance Components
AEAL 1	A0–A1, B0	Declared ST; deterministic brokers; ADV_FSP-A; ATE_STAT.1; ATE_JQL.1; AVA_VAN-A.1; AGD_EVI.1; audit logging (FAU_GEN.1)
AEAL 2	A2, B0–B1	+ ATE_STAT.2; ATE_JQL.2; ADV_ARC.1 for brokers; ALC_FLR.2 flaw remediation; AVA_VAN-A.2 adaptive testing
AEAL 3	A2–A3, B2	+ composite evaluation against base guidance document; ATE_STAT.3; ATE_JQL.3; AVA_VAN-A.3; FAG_ESC human escalation gate
AEAL 4	A3, B3	+ mechanized verification of broker logic; AVA_VAN-A.4 adaptive campaign; continuous post-deployment monitoring; FAG_RVK bounded revocation
AEAL 5	A3–A4, B4	+ formal proof of enforcement kernel; AVA_VAN-A.5; independent replication; absolute model exclusion from safety-critical decision paths

- **AIUC-1 Standard:** AICC maps approximately 50% of controls to SFRs, 25% to SARs, and 25% to organizational processes governed by ISO/IEC 42001 [4].

Notably, the eight coverage gaps the OWASP–AIUC crosswalk identifies in AIUC-1 [4] land almost entirely on components already present in CC Part 2 (FIA, FTP, FRU, FAU) or on the extensions proposed here. Agent identity, containment, revocation, and attestation of a component one did not build are the smartcard problems under new names.

9. Limitations

We state the principal weaknesses of this synthesis explicitly.

The framework is argued, not validated. No system has been evaluated under AICC, so every claim here is analytic. This bears hardest on economics: the Certified Configuration Envelope is argued to make AEAL 2–3 viable by amortizing evaluation effort over an envelope rather than repeating it per release, but the cost of a first evaluation

is asserted rather than measured. A worked evaluation of a deployed agent is the most important missing piece of evidence.

ATE_JQL may be unaffordable at low prevalence. Certifying a 0.5% failure rate with a qualified instrument requires a validation set far larger than current practice, and human labeling is the scarce resource. It is possible that some rates currently reported are not measurable at acceptable cost, a conclusion worth establishing rather than avoiding.

ATE_STAT is only as good as D. The declared input distribution is proposed by the party with an interest in its composition, and adversarial review of distributions is an unsolved evaluator-competence problem.

The Boundary Isolation narrows what a certificate says. AICC attests bounded effect, not good behavior. Properties that cannot be deterministically enforced become measured properties rather than claims. Some readers will find this uninteresting; we regard bounded effect as what certification should mean, but this is a position rather than a result.

Base-component guidance may not be forthcoming. The artifact on which the three-role model depends does not exist and model vendors have weak incentive to produce it.

Judge independence may be reportable rather than achievable. If the strongest available judges and generators come from the same small set of frontier models, ATE_JQL.3 degrades to a disclosure requirement.

10. Open Research Challenges and Roadmap

1. **Stratified Judge Qualification:** Where a judge reads a transcript produced by an upstream model, its class-conditional error compounds with that model's own error, and both vary by stratum. For speech input, recognition error is higher for accented and non-standard speech, so a reported rate is least reliable exactly where a disparity is most likely present. Whether measured disparity across strata exceeds instrument-error disparity across the same strata is open, and settling it requires per-stratum confusion matrices rather than a pooled (α, β) .
2. **End-to-End Speech-to-Speech Models:** Direct speech-to-speech models eliminate intermediate text transcripts, removing the primary enforcement point relied upon for input/output validation. Developing real-time audio-domain mediation primitives (FDP_1FF-A) remains an active challenge.
3. **Multi-Agent Emergent Dynamics:** When multiple certified agents interact, compositionality claims become non-linear. Formalizing multi-agent interaction invariants within composite evaluation (ADV_COMP) is an essential next step.
4. **Evaluator Competence Gap:** Traditional CC evaluation laboratories lack deep machine learning testing capability, while AI red-teaming firms lack formal software assurance experience. Standardizing laboratory accreditation guidelines under ISO/IEC 17025 for ML metrology is critical.

11. Conclusion

Applying traditional Common Criteria to autonomous AI agents as written is impossible: determinism, TSF decomposability, and configuration stability are fundamentally violated. However, empirical industry alternatives discard valuable rate-based data, lack compositional frameworks for model vendors, and rely on uncalibrated measurement instruments whose errors dominate reported outcomes.

What we believe is genuinely absent elsewhere is the metrological layer: a certification framework that cannot state its own measurement uncertainty is not yet a measurement framework. By enforcing the Boundary Isolation, establishing Egress-Path Completeness, qualifying LLM judges as measurement instruments, and defining a graduated AEAL ladder, AICC makes agent failure modes bounded, assurance claims comparable across vendors and jurisdictions, and residual risk priceable with a stated error bar, which is what certification is for.

CRedit authorship contribution statement

Joo Yeon Cho: Conceptualization, Methodology, Formal analysis, Investigation, Writing – original draft, Writing – review and editing.

Declaration of competing interest

The author declares that he has no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Declaration of generative AI and AI-assisted technologies in the writing process

Data availability

No data were used for the research described in this article.

References

- [1] AIUC Consortium, AIUC-1: The standard for AI agent security, safety and reliability, 2026. URL: <https://www.aiuc-1.com/>.
- [2] A. Abromeit, Common Criteria certification of AI systems (C11c), in: Proc. Int. Conf. EU Cyber Security and Resilience Acts (EUCRA), Brussels, 2024.
- [3] OWASP GenAI Security Project, OWASP Top 10 for Agentic Applications, Version 1.0, 2025. URL: <https://genai.owasp.org/>.
- [4] OWASP GenAI Security Project, AIUC-1: Crosswalks OWASP Top 10 for Agentic Applications, Version 1.0, 2026.
- [5] Stanford University Information Security Office, AI Security Framework (AISF), 2026. URL: <https://uit.stanford.edu/security/agentica/security-framework>.
- [6] I. Azouani, et al., Agnostic AI protection profile in the era of the EU AI Act (B31b), to be presented at the 25th Int. Common Criteria Conf. (ICCC), Rome, 2026.
- [7] CCRA, Common Criteria for Information Technology Security Evaluation, ISO/IEC 15408:2022, Release 1, 2022.
- [8] CCRA, Common Evaluation Methodology (CEM), ISO/IEC 18045:2022, Release 1, 2022.

- [9] R. Kvist, R. Dattani, B. Wang, Underwriting superintelligence, 2025.
URL: <https://underwriting-superintelligence.com/>.
- [10] S. Nielson, et al., Strategies for CC compliance for systems with LLMs (C30b), to be presented at the 25th Int. Common Criteria Conf. (ICCC), Rome, 2026.
- [11] E. Whitfield, AIUC-1 Certification Requirements and Eligibility, 2026. URL: <https://standard.aiuc-1.com/aiuc-1-certification>.
- [12] O. Mayraz, CamoLeak: Critical GitHub Copilot Vulnerability Leaks Private Source Code, 2025.
URL: <https://www.legitsecurity.com/blog/camoleak-critical-github-copilot-vulnerability-leaks-private-source-code>.
- [13] W. J. Rogan, B. Gladen, Estimating prevalence from the results of a screening test, *American Journal of Epidemiology* 107 (1) (1978) 71–76. <https://doi.org/10.1093/oxfordjournals.aje.a112510>.
- [14] J. Reiczigel, J. Földi, L. Ózsvári, Exact confidence limits for prevalence of a disease with an imperfect diagnostic test, *Epidemiology and Infection* 138 (11) (2010) 1674–1678.
- [15] Z. Lang, J. Reiczigel, Confidence limits for prevalence of disease adjusted for estimated sensitivity and specificity, *Preventive Veterinary Medicine* 113 (1) (2014) 13–22.
- [16] C. J. Clopper, E. S. Pearson, The use of confidence or fiducial limits illustrated in the case of the binomial, *Biometrika* 26 (4) (1934) 404–413.
- [17] D. G. Altman, J. M. Bland, Diagnostic tests 2: predictive values, *BMJ* 309 (6947) (1994) 102.
- [18] JCGM, Evaluation of Measurement Data — Guide to the Expression of Uncertainty in Measurement (GUM), JCGM 100:2008, 2008.
- [19] L. Zheng, W.-L. Chiang, Y. Sheng, et al., Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena, in: *Advances in Neural Information Processing Systems* 36 (Datasets and Benchmarks Track), 2023.